

DevSecOps: Quick Guide to Process, Tools, and Best Practices

What Is DevSecOps (DevOps Security)?

10 Minute Read

DevSecOps is the convergence of development, security, and operations. It is an organizational pattern that aims to adopt security from the beginning of the software development life cycle (SDLC) through to the end.

Previously, security was added to applications later in the life cycle, after development was complete. Agile development practices and advances in cloud platforms, microservices, and containers, make this impractical, because security cannot keep up with rapid releases.

DevSecOps solves this problem by integrating security with DevOps. Security becomes an integral, automated part of continuous integration (CI) and continuous delivery (CD) pipelines, and a responsibility shared by all teams. Developers become aware of security practices and implement them from the onset of a development project.

This is part of an extensive series of guides about [hacking](#).

In this article:

- [DevSecOps Benefits and Challenges](#)
- [What Is a DevSecOps Pipeline?](#)
 - [Threat Modeling](#)
 - [Security Testing](#)
 - [Analysis and Prioritization](#)
 - [Remediation](#)
 - [Monitoring](#)
- [What Are DevSecOps Tools?](#)
- [DevSecOps Best Practices](#)

- [Shifting Security Left](#)
- [Security Training](#)
- [Workplace Culture](#)
- [Observability and Monitoring](#)

DevSecOps Benefits and Challenges

DevSecOps provides the following benefits:

- **Fast, cost-effective delivery**—traditional software development methods often result in huge bottlenecks and delays due to security issues. Addressing security flaws and fixing code is often time-consuming and costly. DevSecOps enables faster, secure software delivery to save time and reduce technical debt, thus lowering costs by reducing the need for repeated processes at the end of the delivery cycle.
- **A proactive approach to security**—DevSecOps introduces security processes at the beginning of the software development cycle and ensures the code passes continued reviews, audits, tests, and scans throughout the development pipeline. Development teams can address security issues immediately when discovered, remediating problems before they introduce more dependencies. This approach makes security more effective and less expensive.
- **Fast vulnerability remediation**—DevSecOps helps teams identify security vulnerabilities quickly and apply patches early. It integrates vulnerability detection and patching into the development cycle to prevent the release of the vulnerable software. Early patching also reduces the opportunity for threat actors to exploit vulnerabilities, especially for publicly exposed common vulnerabilities and exposures (CVEs).
- **Automation-driven development**—DevSecOps teams can integrate security testing into automated test suites, enabling streamlined operations. Organizations can leverage continuous integration/continuous delivery (C/CI) pipelines to automate development and security processes.

The main objective of DevSecOps is to introduce security processes early in the development lifecycle, helping reduce vulnerabilities and aligning IT and business objectives with security requirements.

However, organizations may also face obstacles when adopting DevSecOps, especially if they lack the proper governance strategies, technologies, and expertise. Usually, hiring or retraining staff is necessary to provide security skills and adjust the development team's responsibilities. There is a shortage of security professionals with DevSecOps experience, and developers often struggle to embrace a security-driven culture.

Each organization has unique challenges and must determine the best DevSecOps strategy for its existing infrastructure, policies, and business needs. Businesses can overcome these

challenges, especially once management, development, IT, and security teams realize the benefits of implementing DevSecOps.

Learn more about the tight connection between [DevOps and security](#)

What Is a DevSecOps Pipeline?

Here are the main stages of a DevSecOps pipeline. These are the security-oriented stages that occur alongside traditional DevOps pipeline stages—such as planning, development, testing, and deployment.

1. Threat Modeling

Threat modeling outlines possible attack scenarios, describes sensitive data flows, vulnerabilities, and potential mitigation options. This step helps close the security gap and improve security knowledge for everyone on the team.

2. Security Testing

Scanning is the process of analyzing code, artifacts, and running software to identify security weaknesses. This includes manual and automated code reviews, application security tools such as static/dynamic application security testing (SAST/DAST), vulnerability assessment, and penetration testing. This step allows developers to address security vulnerabilities and bugs early in the software development lifecycle.

3. Analysis and Prioritization

The analysis phase identifies security risks by reviewing all data and metrics collected during security testing. These risks are then aggregated into a list and prioritized by their potential business impact and likelihood of exploitation.

4. Remediation

After identifying and security vulnerabilities in the previous steps, teams take steps to remediate those vulnerabilities. Continuous testing tools, and processes like penetration testing, provide actionable guidance on how to address security weaknesses. Teams can then address vulnerabilities in order of priority.

5. Monitoring

Monitoring involves tracking the overall security posture of an application, to identify new vulnerabilities or misconfigurations that can occur while it is running in production. In addition, monitoring is critical for discovering threats and security breaches. When a threat is discovered or a breach occurs, lessons should be learned to improve the DevSecOps process and prevent similar incidents in the future.

What Are DevSecOps Tools?

Tools are an integral part of DevSecOps. This is because in a fast-changing DevOps environment, security must be automated and tightly integrated with the CI/CD pipeline.

DevSecOps tools have three main goals:

- **Continuous security testing**—detects security vulnerabilities as soon as they occur, minimizing risk and allowing rapid remediation without slowing down the development pipeline.
- **Support security teams**—enabling easy monitoring and control over development projects without having to manually review and approve each release.
- **Support development teams**—assisting developers in applying secure coding practices. Automated tools can notify developers about security issues during all stages of development, to enable quick fixes and promote developer security education.

DevSecOps Best Practices

DevSecOps is the seamless integration of security processes and controls into the development and delivery pipeline. Here are some best practices to help ensure effective DevSecOps implementation.

Shifting Security Left

Shifting left is the core principle of DevOps and, by extension, DevSecOps. It involves moving processes—in this case, security—from the end of the delivery process to the beginning, known as the “left” of the pipeline. DevSecOps environments place security at the start of the development lifecycle, requiring software and security engineers to collaborate with the development team.

The DevSecOps team is collectively responsible for ensuring each component and configuration is secure. Every team member must implement security patches and document their processes. Shifting security left allows the team to discover security risks early, enabling the immediate remediation of security threats and facilitating rapid, smooth delivery cycles. The developers consider security in addition to their traditional build processes.

Security Training

Security requires a combination of compliance and software engineering processes. Developers, software engineers, and security specialists should work closely with the compliance department to keep everyone up-to-date with the organization's security policies. All employees should undergo periodic training to ensure they understand their responsibilities.

All individuals involved in the software delivery process must be familiar with basic application security principles, including awareness of the Open Web Application Security Project (OWASP), security testing processes, and software engineering best practices. Developers must understand threat models and compliance assessments. They should know how to identify and measure security risks and exposures and apply security controls.

Workplace Culture

Successful DevSecOps require a workplace culture that embraces change and takes security seriously. An organization's leadership should encourage collaborative attitudes and promote communication to enable a unified security effort. Developers and software engineers must take ownership of the security processes incorporated into the delivery cycle.

The DevSecOps team should establish a system that incorporates appropriate practices and technologies. The team should be free to create a workflow environment that suits its needs, allowing each team member to become invested in the project's success.

Observability and Monitoring

Maintaining security requires continuous monitoring and observability solutions to provide security insights and help keep track of the development environment's risks. An effective observability strategy should incorporate the following elements:

- **Visibility**—the ability to view the development and security processes is essential for maintaining DevSecOps environments. Organizations must use monitoring systems to measure operations, generate alerts, and provide awareness of threats and attacks. Visibility is important for ensuring accountability throughout the project's lifecycle.
- **Traceability**—organizations must be able to track security configurations and code issues throughout the development pipeline. It is essential for enforcing controls and helps organizations maintain compliance, minimize bugs, secure the code, and facilitate code fixes.
- **Auditability**—organizations must conduct audits to comply with internal security policies and government regulations. All security controls must be auditable and well-documented.

DevSecOps with HackerOne

HackerOne helps organizations accelerate the journey to DevSecOps by combining the expertise of the world's largest community of ethical hackers with a seamless platform that orchestrates workflows, testing programs, scoping and reports.

HackerOne bridges requirements across development and security teams that:

- Helps application development teams deliver software with fewer flaws
- Fosters collaboration and trust between security and development teams
- Extends the reach of security by educating developers to look for ways to reduce vulnerabilities
- Optimizes security practices for the scale and speed needed for modern application development and deployment
- Improves adherence to compliance, legal and regulatory requirements

With a faster path to DevSecOps with solutions from HackerOne, organizations will release applications with a greater resistance to attack while maintaining the speed of their DevOps pipeline.

Learn more about the [HackerOne Security Platform](#).

See Our Additional Guides on Key Cybersecurity Topics

Together with our content partners, we have authored in-depth guides on several other topics that can also be useful as you explore the world of [Cybersecurity](#).

[Attack Surface](#)

- [What Are Attack Vectors and 8 Ways to Protect Your Organization](#)
- [What Is Attack Surface Management and a 5-Step ASM Process](#)
- [What Is External Attack Surface Management \(EASM\)? | HackerOne](#)

[Vulnerability Assessment](#)

- [What is Vulnerability Scanning? \[And How to Do It Right\]](#)
- [Vulnerability Management: 4 Steps to Successful Remediation](#)
- [5-Step Security Risk Assessment Process](#)

Command Injection

Authored by Bright Security

- [Code Injection Example: A Guide to Discovering and Preventing attacks](#)
- [PHP Code Injection: Examples and 4 Prevention Tips](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker?

